Q1 — Information Security Policy: Approval and Publication Record

AutoClip | TikTok Shop Partner Security Review | 30 October 2026 | Revised evidence edition

Status: POLICY DRAFT. Original Policy v3.0 follows unchanged; it is not yet approved or published.

Required prior to Q1 submission

• Fill in the registered legal entity, authorized approver name/title, approval date, policy effective date and next review date in the policy.

• Formally approve and publish the actual v3.0 policy; retain evidence of its publication location and relevant administrator acknowledgement.

• Replace this provisional approval cover and the unsigned policy with the genuinely approved version before submitting as a published policy.

Consistency notes

• The original policy is version 3.0 dated 30 October 2026; Q6 and Q7 supporting reports have been corrected to reference v3.0 rather than v1.0.

• No signature or approval is fabricated in this package.

Document control: Owner: AutoClip operator | Approval: pending | Reviewer/date: _____

Evidence rule: Only claim a control as operational after reviewing dated production or workstation evidence. Do not include secrets or personal data in screenshots.

Information Security & Privacy Policy

TikTok Shop Partner — Data Security & Privacy Review

Document version	**3.0**
Effective date	Upon formal approval
Document status	Prepared for owner approval — not yet attested as operational
Policy owner	AutoClip Owner / Incident Lead
Security contact	diogos.nascimento@outlook.com
Legal entity	[INSERT REGISTERED LEGAL ENTITY]
Approver / approval date	[INSERT NAME AND APPROVAL DATE]
Review cadence	At least annually and after material security changes

1. Purpose and scope

This policy defines the security and privacy controls, responsibilities and incident-response requirements for AutoClip, a multi-tenant application that connects authorized TikTok and TikTok Shop accounts, manages media and schedules or initiates publication workflows. It applies to application code, Supabase services, storage, operational accounts, third-party integrations and personnel administering the service.

This policy distinguishes controls evidenced by reviewed repository code from operational controls requiring configuration, testing, monitoring or formal adoption. It is not a certification, independent penetration test or statement of TikTok Shop approval.

2. Governance and accountability

The AutoClip Owner is accountable for security decisions, access management, incident coordination, vendor oversight, policy approval and annual review. The Owner acts as Incident Lead, with authority to suspend affected integrations, rotate secrets, approve external notices and track remediation. A delegate must be designated for material incidents when the Owner is unavailable.

Security reports may be directed to diogos.nascimento@outlook.com. The mailbox must be actively monitored as part of operational adoption.

3. Identity, access control and tenant isolation

- Access to application data is based on authenticated identities, workspace membership and assigned roles; SQL row-level security (RLS) policies and role helpers are defined in repository migrations.
- Backend-only operations use service credentials; such credentials must never be embedded in browser-delivered code. Privileged database functions must validate workspace membership and limit returned fields.

- The TikTok Shop connection listing function exposes a restricted connection summary rather than encrypted access and refresh tokens. Direct SELECT permission on the token-bearing connection table is revoked from authenticated users in migration 20261101000001.
- TikTok Shop publication code verifies the association between the publication job, media asset, affiliate product, channel and workspace before sending media.
- Production authorization must be validated with negative tests for cross-workspace access, owner-role changes, and privilege escalation; migrations alone do not prove runtime enforcement.

4. Credential protection and OAuth

- OAuth access and refresh tokens are encrypted server-side using AES-256-GCM with a random initialization vector and connection-specific additional authenticated data, as implemented in the shared crypto module.
- OAuth callbacks use a one-time state consumption mechanism; the relevant database function and deployed behavior must be periodically tested.
- TikTok Shop token refresh and callback handlers verify persistence results before reporting success.
- Secrets such as TOKEN_ENCRYPTION_KEY, WORKER_SECRET and TikTok Shop app credentials must reside in protected server-side secret stores with restricted access and a documented rotation process.
- Token exchange and refresh follow the provider integration contract; URLs containing credentials or authorization codes must not be recorded in application, proxy, analytics or infrastructure logs.

5. Media handling and publication integrity

- Media assets are linked to workspace-scoped records. The TikTok Shop publication service retrieves media through the job-associated asset rather than accepting an arbitrary client-provided storage path.
- Worker requests require an internal shared secret; worker secret distribution and rotation must be controlled.
- A publication-in-progress marker and conditional database update reduce duplicate external publication on concurrent attempts or retries. Interrupted publications require a reconciliation workflow and operator review before any replay.
- Media delivery uses signed URLs or signed proxy tokens where configured; the public domain used for TikTok media retrieval must be verified and HTTPS-enabled.
- The service must apply retention and deletion rules to media, tokens, job history and audit records, subject to legal obligations and provider terms. Actual retention periods must be approved and configured before they are represented as enforced.

6. Logging, monitoring and vulnerability management

Security-relevant events should be recorded with UTC timestamps, actor or service identity, workspace context, action, outcome and correlation identifier, without plaintext tokens or secrets. Access to logs must be limited to authorized operators. Monitor authentication anomalies, authorization failures, unexpected token refreshes, worker errors, publication reconciliation exceptions and suspected cross-tenant access. Track findings by severity, owner, remediation and verification date.

Changes should undergo code review and automated checks where available. Before deployment, execute application tests, database authorization tests and integration tests in an appropriately isolated environment. Production environment variables and provider dashboards require separate review.

7. Privacy, minimization and data rights

Collect and process only information required to connect accounts, identify authorized users and workspaces, manage media, synchronize permitted affiliate product information, publish authorized content, and maintain operational or security records. Access to account identifiers, media and activity records must be limited to their intended purpose. Requests for access, correction, export or deletion must be assessed under applicable law and provider requirements. Account disconnection should trigger revocation or invalidation of relevant credentials and appropriate data lifecycle actions.

AutoClip must not sell user data or use TikTok/TikTok Shop data for unrelated purposes without a valid legal basis and required permissions. Data-sharing and subprocessor arrangements must be reviewed and accurately disclosed in public privacy notices.

8. Incident response and breach notification (Q16)

The documented incident response process is maintained in docs/INCIDENT_RESPONSE_RUNBOOK.md. The Incident Lead coordinates identification, triage, containment, investigation, notification, recovery and post-incident review. A suspected incident includes unauthorized access or disclosure, token compromise, cross-workspace access, malware, account compromise, data alteration or material service disruption.

- Record the UTC discovery time, reporter, affected services, available evidence and an incident ID in an access-controlled register.
- Classify the incident as Critical, High, Medium or Low based on actual or suspected exposure and impact.
- Contain promptly by suspending affected workflows, revoking or rotating credentials, restricting access and preserving relevant evidence.
- Assess affected tenants, data categories, accounts, geographic scope, timing, root cause and applicable notification obligations.
- Notify TikTok Shop through the applicable Partner Center or official support channel without undue delay for material TikTok Shop incidents, and notify customers, individuals, regulators or suppliers when legally or contractually required. Apply any stricter contractual or statutory deadlines.
- Document recipients, basis, notification time, known facts, mitigation steps, contact channel, recovery decision and corrective actions.
- Perform a documented tabletop exercise at least annually and after material changes to authentication, token handling or multi-tenant access.

Operational readiness requirement: the Owner must actively monitor the security mailbox, maintain a protected incident register, designate backup coverage and complete/document an initial tabletop exercise. The existence of the runbook alone does not establish that these activities have occurred. Q16 should be answered “Yes” only after the process has been formally adopted and can be demonstrated.

9. Continuity, recovery and third-party dependencies

Maintain documented procedures to restore essential publication and account-management functions after service disruption, including safe retry handling and reconciliation of TikTok Shop publishing. Review Supabase, hosting, storage and TikTok/TikTok Shop dependencies; preserve backups where supported and test recovery according to approved recovery objectives. Do not assume third-party availability or backups without verification.

10. Evidence register and verification boundaries

Evidence category	Artifact / qualification
Repository evidence	docs/INCIDENT_RESPONSE_RUNBOOK.md — incident ownership, triage, notifications, incident register and annual exercise requirement.
Repository evidence	supabase/migrations/20261020000002_rls.sql — core workspace-scoped RLS policies and authorization helpers.
Repository evidence	supabase/migrations/20261101000001_lock_down_tiktok_shop_tokens.sql — connection table SELECT restriction and safe listing RPC.
Repository evidence	supabase/migrations/20261101000002_shop_publish_reconciliation.sql — publication reconciliation marker and index.
Repository evidence	supabase/functions/tiktok-shop-publish/index.ts — workspace/media/product association, worker authentication and duplicate-publication guard.
Repository evidence	supabase/functions/tiktok-shop/index.ts and tiktok-shop-oauth-callback/index.ts — OAuth token handling and persistence checks.
Reported remote status	Project review reported migrations 20261101000001 and 20261101000002 as applied remotely; not independently verified in this document.
Not independently verified	Production secrets, Vercel configuration, complete RLS integration tests, incident mailbox monitoring, incident register operation and initial tabletop exercise.

11. Approval and review

This version is prepared for formal adoption. The organization should approve the policy only after confirming that operational responsibilities, configurations and procedures are implemented. Any statement in a partner questionnaire must match actual practices at submission time.

Approved by: _____ Date (UTC): _____

Legal entity: _____ Next review date: _____

Change history: v3.0 — Added verified repository references, TikTok Shop token-table lockdown, publication reconciliation safeguards, documented incident runbook and explicit operational readiness qualifications.